

Modbus TCP 접근통제 진단

가상 OT 환경에서 정상 기준선부터 개선 판단까지

인더포레스트 보안 컨설팅 직무 지원 포트폴리오

OpenPLC · FUXA · Modbus TCP · Docker · Python

공개 저장소 github.com/pepcloud/ics-security-assessment-lab

지원 직무와 프로젝트의 접점

02

OT 환경의 통신을 읽고, 통제된 시험으로 원인과 영향을 설명하는 역량

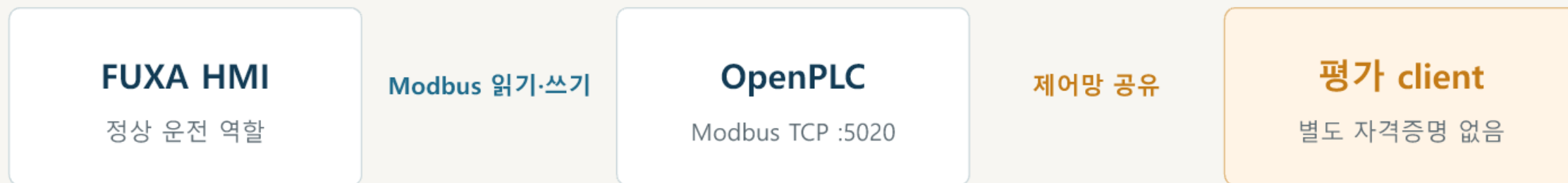
JD 요구	포트폴리오에서 제시한 증거
OT·PLC·ICS 진단	OpenPLC와 FUXA를 연결하고 Modbus 명령과 공정 상태를 함께 분석
취약점 시험환경 구성	Docker 네트워크로 정상 HMI와 평가자 역할을 분리해 비교
결과 보고서 작성	시험 매트릭스, Finding, 원본 로그, PCAP 해석을 상호 연결
스크립트·자동화	Python 검증 도구와 PowerShell 증적 수집 절차 작성

범위 소유한 가상 환경에서 수행한 OT 접근통제 진단이다. 블랙박스 모의해킹, 신규 CVE 발견, 실제 설비 평가를 주장하지 않는다.

시험환경과 신뢰 경계

03

개선 전에는 HMI와 일반 평가 client가 같은 제어망에서 PLC 5020 포트에 도달했다



태그 대응

수위 HR0

명령 Coil 0

운전 상태 Coil 1

고수위 경보 Coil 2

핵심 판단

이 구성에서는 TCP 5020 도달 가능성이 사실상 명령 권한의 경계로 작동했다.

- | | | |
|----|--------|-------------------------------------|
| 01 | 정상 기준선 | 정지 상태와 ON·OFF 운전 패킷을 먼저 수집 |
| 02 | 가설 설정 | 일반 client가 동일 제어망에서 명령을 바꿀 수 있는지 확인 |
| 03 | 제한된 재현 | 펌프 명령 1회, 3초 관찰, finally 절에서 OFF 복원 |
| 04 | 원인과 개선 | 프로토콜 특성과 배치 문제를 구분하고 평가망 분리 |
| 05 | 재검증 판단 | DNS 실패만으로 차단을 확정하지 않고 판정을 낮춤 |

중단 조건 예상하지 못한 값, 갱신 중단, 반복 timeout, 복원 실패가 발생하면 쓰기를 중단하고 상태를 확인

27쌍

정지 상태 요청·응답

120쌍

ON·OFF 운전 요청·응답

0 → 6 → 0

관찰한 수위 변화

00 → 03 → 00

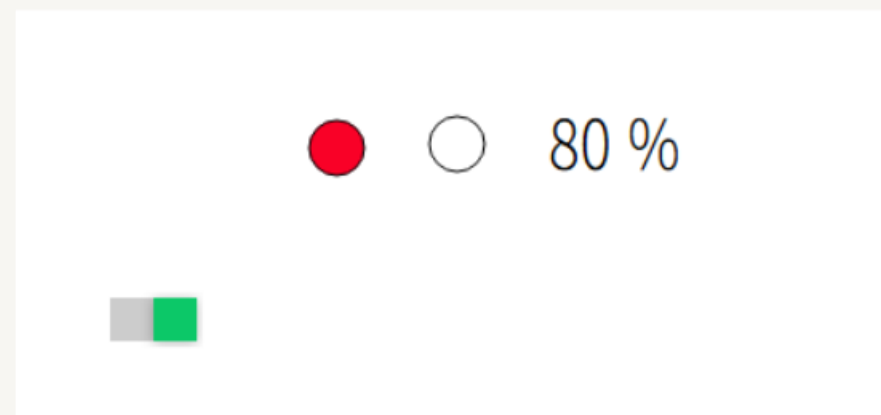
Coil 상태 바이트

패킷에서 확인한 동작

FC03 Holding Register 0 읽기

FC01 Coil 0부터 3개 상태 읽기

FC05 Coil 0에 ON 0xFF00, OFF 0x0000 쓰기



FUXA 80% 고수위 경보 관찰 화면

정지 캡처는 13.011초이며 장시간 안정성을 의미하지 않는다.

Finding AC-01 제어망 내부의 제한 없는 Modbus 명령 접근

06

이 실습의 신뢰 모델에서 높음

관찰

같은 제어망의 일반 client가 FUXA 세션이나 PLC 자격증명 없이 Coil 0 명령을 ON으로 변경했다.

0 → 3

시험 중 수위

true

pump_command

true

pump_running

OFF

시험 후 복원

원인

OpenPLC, FUXA, 평가 도구가 하나의 평면 네트워크를 공유했고 Modbus 자체에서 client 역할을 구분하지 않았다.

영향 범위

가상 펌프 명령과 상태 변화까지 확인했다. 실제 설비의 물리 피해나 제품 취약성은 검증하지 않았다.

개선과 재검증 판단

07

평가 도구를 별도 internal assessment 네트워크로 이동하고 PLC·HMI는 control에 유지

control

FUXA ↔ OpenPLC:5020

네트워크 분리

assessment

평가 client

재검증 항목	현재 판정	판단 근거
이름 기반 접속	관찰 확인	DNS 오류로 Modbus 단계에 도달하지 못함
직접 IP TCP 5020	미검증	DNS 실패로 대체 판정하지 않음
허용된 HMI 운전	부분 확인	운영자 관찰과 정지 화면, 조치 후 PCAP 없음

잘못된 확신보다 증거의 범위를 좁혀 쓰는 판단을 선택했다.

시험	판정	핵심 증적
MB-01 정상 Modbus 분석	PASS	정지 27쌍, 운전 120쌍 PCAP 분석
AC-01 제어망 도달	PASS	일반 client의 초기 태그 읽기
AC-02 제한된 명령 쓰기	PASS	수위 0→3, 명령과 상태 확인, OFF 복원
RT-IP 직접 IP 차단	NOT TESTED	자동 수집 절차 작성, 실행 증거 없음
OP-01 조치 후 HMI	PARTIAL	운영자 관찰과 정지 화면, 새 PCAP 없음

재현성

원본 로그·PCAP·SHA-256·시험 매트릭스를 연결하고, 새 실행은 별도 Run ID로 보존

자동화

환경 식별과 신뢰·비신뢰 TCP 경로 대조를 PowerShell 한 번으로 수집

패킷 하나를 취약점으로 단정하지 않고 공정 상태와 배치 조건까지 확인했습니다

정상부터 확인	정상 HMI의 읽기·쓰기 패턴을 기준선으로 확보한 뒤 평가했다.
영향을 연결	Modbus 응답 성공과 실제 펌프 상태·수위 변화를 함께 확인했다.
한계를 기록	제품 취약성, 실제 물리 영향, 표준 준수를 결과 범위에서 제외했다.
판정을 수정	DNS 실패를 네트워크 차단으로 보지 않고 재검증 상태를 낮췄다.
재현성을 남김	시험표, 원본 증적, 해시와 재시험 절차를 공개 저장소에 연결했다.